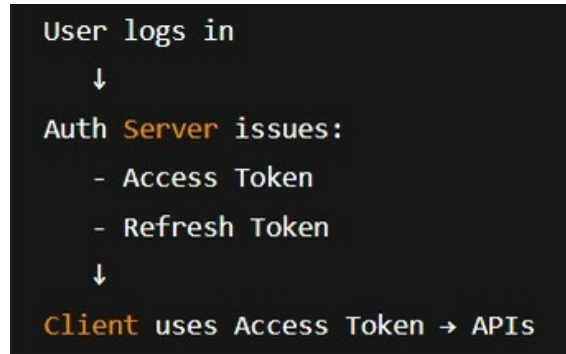


Access token v.s. Refresh token

- On **first login**, auth server usually issues **both**

✓ Access token

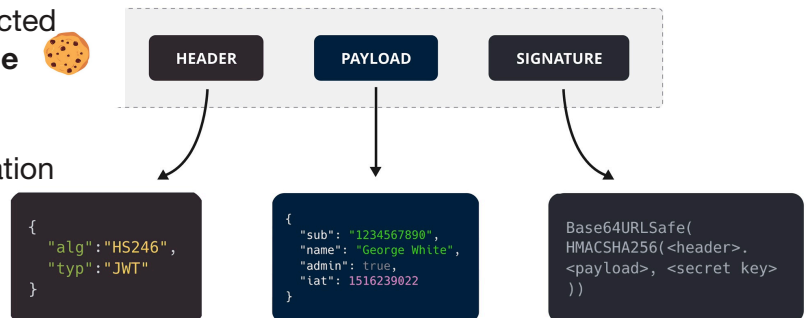
- Sent with **every** API request
- Stored in **HTTP-only, Secure cookie** (best) / memory
- proves you're **allowed** to access this resource
- Short-lived**(5-15 mins), frequently exposed
- JWT** = Access token
- ✗ Not** stored in **DB** 
- Verified** via **signature** + expiry
- Stateless (not stored on server)
- Contains **user id, role, expiry**



✓ Refresh token

- Sent **ONLY** when **access token expires**
- Sent to auth server, not APIs
- Get a **new access token**
- Long-lived**(5-30 days), tightly protected
- Stored in **HTTP-only, Secure cookie**  (Best) / Keychain / Keystore
- Stored in **DB** (hashed) 
- Required for logout, revocation, rotation

Structure of a JSON Web Token (JWT)



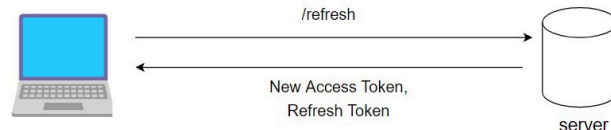
Refresh token validation flow

- Client** sends **refresh token**
- Server **hashes** it
- DB lookup** for match
- Check expiry / revocation / reuse
- If **valid** → issue **new tokens**

On refresh:

- Old token is invalidated
- New refresh token is issued

When Access Token Expires or User Refreshes



Access Token expires

